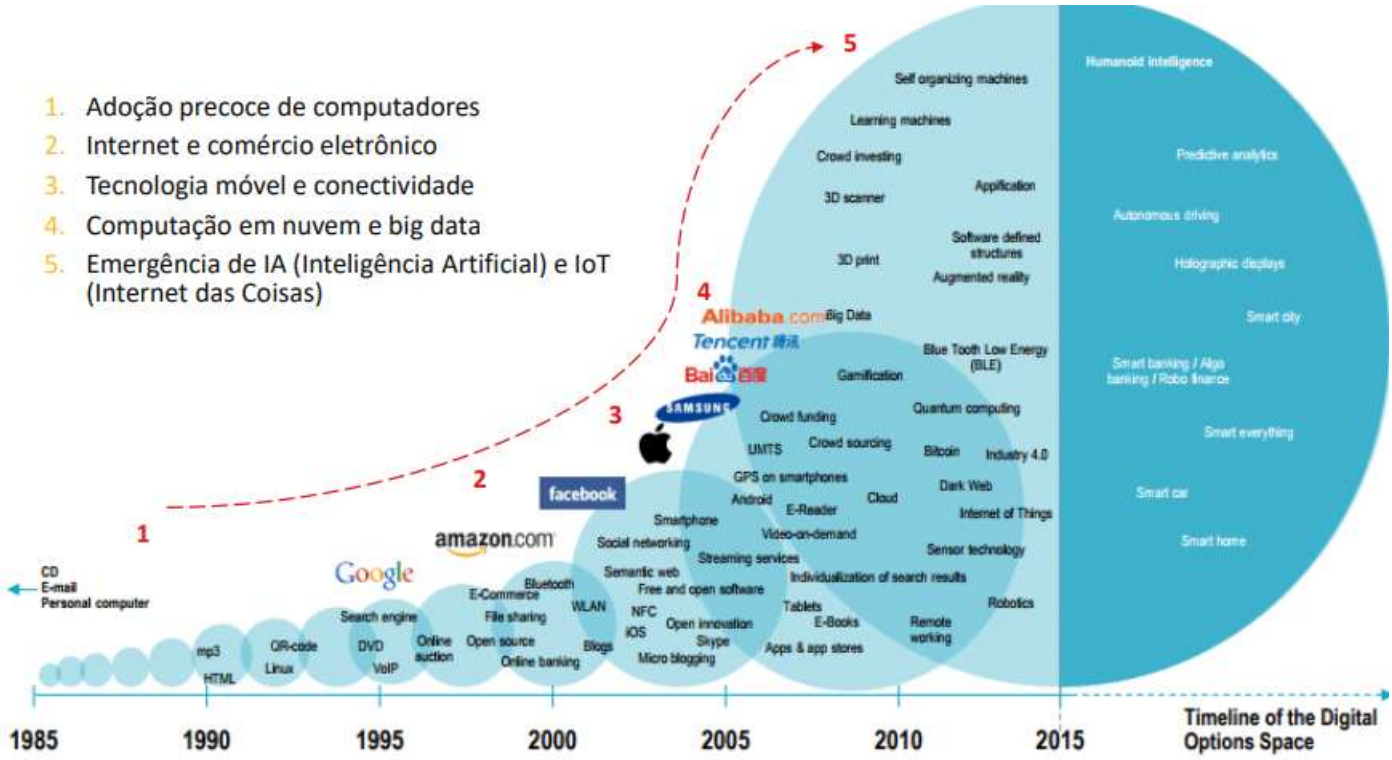
SEGURANÇA E PRIVACIDADE

2 de março de 2026 23:04



Digitization (Conversão de Dados) - **converter** informações do formato **físico** para o formato **digital** ex: escanear uma fatura de papel e guardá-la como um arquivo pdf.

Digitalization (Transformação de Processos) - **uso** dessas informações **digitais** e das tecnologias para **melhorar processos** ex: usar faturas digitais para criar um fluxo de trabalho automatizado em que o sistem aprova sem intervenção humana.

Digital Transformation (Estratégia e Cultura) - **mudança cultural e estratégica** em toda a organização, com foco na estratégia, no cliente e na inovação corporativa ex: os sistemas informáticos dos fornecedores passam a "falar" diretamente com o sistema da empresa em tempo real.

Tipo de Ameaças

1. **Ransomware Attacks** - malware que "sequestra" os dados da vítima, **criptografando arquivos** e **exige um pagamento** (resgate)

2. **IoT Vulnerabilidade** - **senhas fracas**, redes inseguras ou interfaces inseguras

3. **Social Engineering and Phishing Attacks** - **manipulação de pessoas** para que realizem ações ou revelem informações confidenciais e o **phishing** é um método específico (emails

ou mensagens falsas) para roubar dados

4. **Supply Chain Attacks** - ataca uma organização indiretamente, o hacker explora o "elo mais fraco" da cadei em vez de atacar a empresa principal

5. **AI-Powered Cyber Threats** - criminosos utilizam ferramentas de **IA para automatizar**, acelerar e tornar os seus ataques mais sofisticados e difíceis de detetar

6. **Advanced Persistent Threats APTs** - ataque prolongado e altamente direcionado, o invasor permanece, indetetável, objetivo não é causar danos imediatos mas sim r**oubar informações sensíveis de forma contínua** e sorrateira.

7. **Zero-Day Exploit** - aproveita de uma **falha de segurança** num software que ainda é **desconhecido** pelos próprios criadores

8. **Cloud Security Risks** - ameaças, vulnerabilidades e desafios na **cloud**

9. **Mobile Malware and Vulnerabilities** - programas criados para **atacar sistemas ANDROID e o iOS**, roubar **dados pessoais**, aceder a **contas bancárias**, espiar o utilizador

10. **Insider Threats** - dentro da **própria organização**, ataque de alguém de confiança.

11. **AI Misuse** - uso de **sistemas e ferramentas IA** de forma maliciosa por atacantes para **cometer crimes**

12. **Data Breaches and Privacy Violations** - informações confidenciais são acedidas, roubadas por pessoas não autorizadas, quebra das regras, leis ou da confiança no tratamento dos meus dados pessoais ex: a **empresa pode vender ou partilhar os meus dados sem a minha autorização**.

13. **Advanced Phishing Techniques** - ex: **criação de um sistema falso moderno** onde pede uma senha e um código por SMS

14. **Nation-State Cyber Attacks** - operações digitais ofensiva orquestradas pelo **governo de um país contra os interesses de outra nação**.

15. **Cryptocurrency-Related Threats** - **esquemas para roubar ativos digitais** (como Bitcoin), comprometer carteiras virtuais ou explorar vulnerabilidades nas redes blockchain e plataformas de câmbio

Cibersegurança é a prática de **proteger redes**, dispositivos, aplicativos, sistemas e dados de ameaças cibernéticas. O objetivo geral é **evitar ataques que tentem aceder** a/ou **destruir dados**, **extorquir dinheiro** ou interromper operações normais de negócios, sejam

internas ou externas à organização.

Confidencialidade - os utilizadores tem **acesso apenas à informação necessária** para executar a sua função.

Integridade - precisão e consistência da informação ao longo de todo o seu ciclo de vida, garantindo que **não seja alterada por entidade não autorizadas**.

Disponibilidade - a **informação está disponível sempre que necessário**, assegurando que os processos de negócio funcionem de forma contínua.

NIST "National Institute of Standards and Technology" é uma **agência dos USA**, tem como missão **promover a inovação e a competitividade industrial**, **melhorar a qualidade de vida** e a **segurança**.

1. **Identificar** - identificar e **documentar os ativos, sistemas, pessoas e processos da organização** incluindo ativos críticos, avaliação de risco e a criação de inventário detalhado.

2. **Proteger** - implementar **medidas de segurança para mitigar os riscos identificados**, inclui a **aplicação de controles de acesso**, **políticas de segurança** e **formação de**

colaboradores para aprenderem a reconhecer ataques de phishing.

3. **Detetar** - implementar **sistemas e processos para identificar possíveis incidentes de segurança o mais rápido possível**, o sistema deve detetar comportamentos anormais dos funcionários com avisos.

4. **Responder** - **ações a serem tomadas em resposta a incidentes de segurança** tais como a implementação de planos de respostas a incidentes.

5. **Recuperar** - recuperar **serviços normais após um incidente de segurança**, implementando **planos de recuperação**, análise pós-incidente, ex: backups que estavam guardados offline para restaurar os sistemas e pôr a empresa a funcionar novamente

ISO/IEC 27001 - norma mais conhecida do mundo para **sistemas de gestão de segurança da informação (SGSI)**, ajuda as organizações a se tornarem conscientes dos riscos e a identificar e abordar pro ativamente as fraquezas.

- **Context of the organization (Contexto)** - **quem** são os sócios
- **Leadership (Liderança)** - o dono tem de **aprovar** as regras
- **Planning (Planeamento)** - **planear** onde colocar as câmaras
- **Support (Suporte)** - **treinar** os seguranças
- **Operation (Operação)** - **gerir** o dia a dia
- **Perfomance evaluation (Avaliação)** - **verificar** se as câmaras estão a gravar bem
- **Improvement (Melhoria)** - trocar as fechaduras se alguém perder uma chave

As 4 categorias de Controlos da ISO 27001

- **A05 - Controlos Organizacionais (Organizational controls)** : lida com as **políticas de segurança da informação**, gestão de identidades, uso de serviços na **Cloud** e as responsabilidades da **gestão**.

- **A06 - Controlos de Pessoas (People controls)** : **regras para o trabalho remoto**, acordos de confidencialidade, **processos de entrada e saída** de funcionários (onboarding/offboarding) e a **responsabilidade de reportar incidentes**.

- **A07 - Controlos Físicos (Physical controls)** : como **proteger o espaço físico**, inclui segurança das instalações, monitorização, proteção contra desastres naturais, roubos e destruição intencional.

- **A08 - Controlos Tecnológicos (Technological controls)** : a parte mais técnica, inclui a **autenticação, encriptação, prevenção de fuga de dados**, **segurança da rede** e o mascaramento de dados (**data masking**).

RGPD (Regulamento Geral de Proteção de Dados) - estabelece as **regras da União Europeia** relativas ao tratamento de dados pessoais, aplica-se a empresas que prestam serviços a clientes, mas tem exceções (como o uso de dados para atividades domésticas/pessoais).

Os 7 Princípios do RGPD:

- **Licitude, lealdade e transparência** - o **titular dos dados** tem de ser informado do **motivo e fim da recolha** dos seus dados.

- **Limitação da conservação** - os **dados** só devem ser **guardados pelo tempo estritamente necessário** (exceto para fins de interesse público, histórico, estatístico, etc).

- **Finalidade** - os dados devem ser **recolhidos** para **fins determinados, explícitos e legítimos**.

- **Minimização dos dados** - só deve ser recolhido o **estritamente necessário para o fim em questão**.

- **Exatidão** - os dados têm de ser **mantidos exatos e atualizados**; dados inexatos devem ser apagados.

- **Integridade e confidencialidade** - **garantir** que só **tem acesso quem necessita** e que não há alterações não autorizadas.

- **Responsabilidade** - o **responsável** pelo tratamento tem de **provar que cumpre todos os princípios**

Implementação e Desafios:

- **Prática** - requer mapeamento de fluxos, implementação de medidas técnicas e, por

vezes, a designação de um DPO (Data Protection Officer)

- **Desafios** - exige mudança cultural nas organizações, envolve custos de conformidade e a necessidade de formação contínua.

Análise de Dados em Cibersegurança

Cibersegurança moderna usa dados para prever, detetar e responder a ataques.

Behavioral Analytics (Análise Comportamental) - **analisa** o **comportamento do utilizador** num sistema para detetar padrões anormais que possam indicar uma ameaça. Ex: um único utilizador a fazer downloads em massa ou acessos a partir de localizações atípicas (Atypical Travel). Ex: João acede ao sistema do banco entre as 9h e as 18h, sempre a partir de um IP em Lisboa, um dia, o sistema deteta um login as 3h da manhã de um IP na Rússia (Atypical Travel) e a fazer download em massa dos dados (Mass download by a single user), o sistema reconhece esse comportamento anormal e bloqueia a conta automaticamente antes dos dados serem roubados.

Network Analysis and Visibility - **ferramentas passivas na rede que analisam o tráfego para detetar ameaças** com base em assinaturas e comportamentos, descobrindo relações entre os ativos informáticos. Ex: a fábrica tem sensores de temperatura (dispositivos IoT) ligados à rede para monitorizar as máquinas, o software de análise de rede, que está passivamente a analisar o tráfego, deteta que um dos sensores esta a tentar estabelecer uma ligação com o servidor de BD dos RH, como o sensor de temperatura não tem motivos para "falar" com o servidor de RH, o sistema deteta a ameaça e alerta a equipa de TI.

SOAR (Security Orchestration, Automation and Response) - plataformas que ajudam as equipas de segurança a trabalhar de forma mais inteligente.

- **Capacidades** - gestão de casos/workflows, automação de tarefas repetitivas e inteligência centralizada contra ameaças.

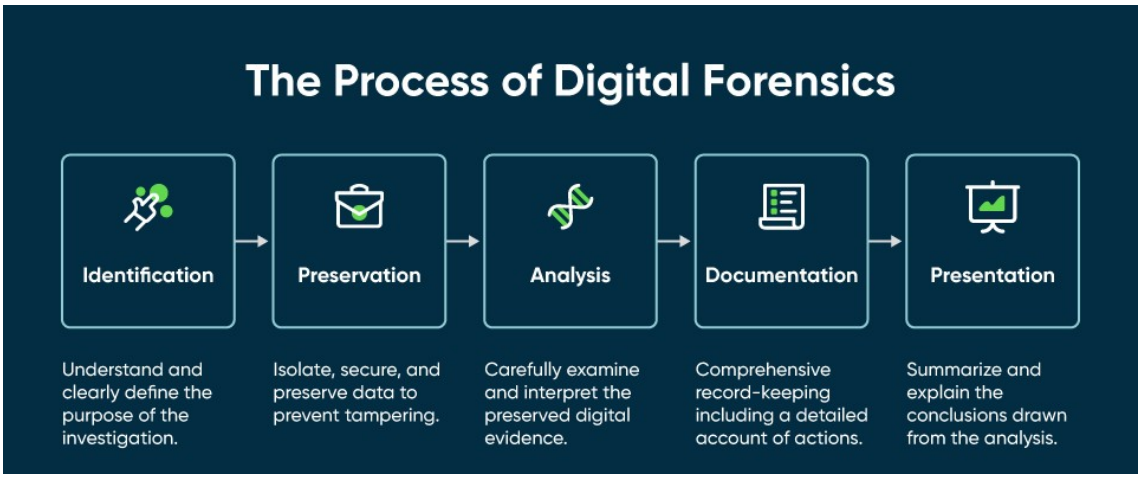
- **Vantagens** - maior produtividade, otimização de custos (até 60%), respostas mais rápidas (reduzindo falsos positivos) e uma visão centralizada das operações.

Exemplo: a empresa recebe cerca de 500 denúncias diárias de emails suspeitos de phishing reportados pelos próprios funcionários, para não ser um analista humano a abrir estes emails todos, o sistema SOAR entra em ação automatizando a tarefa: extrai os links suspeitos, verifica a reputação através de inteligência de ameaças centralizada, bloqueia o domínio malicioso na firewall da empresa e apaga o email, o analista humano só é chamado se o ataque for muito complexo, aumenta assim a produtividade e garante respostas mais rápidas.

Forensics (Forense Digital) - a fase "CSI" da cibersegurança, consiste na recolha, análise e preservação de provas digitais após um incidente.

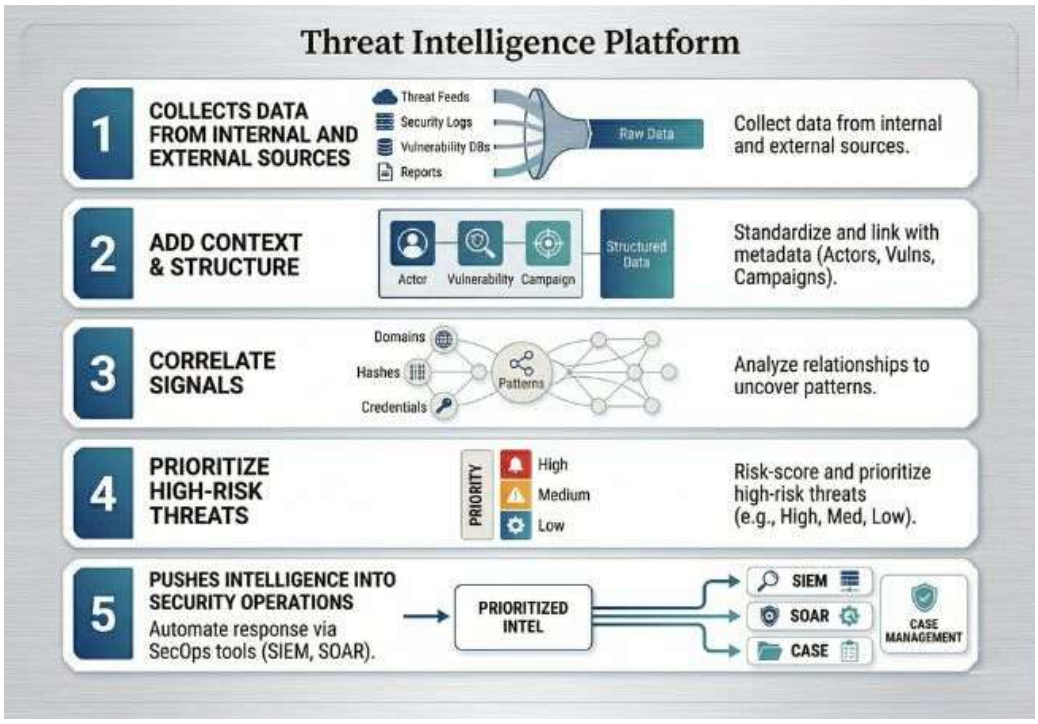
- **Para que serve** : determinar a origem do ataque e apoiar investigações legais
- **Onde procurar** : logs do sistema, tráfego de rede, gravações de vídeo/áudio e cópias de discos rígidos.

Exemplo: empresa sofre um ataque de Ransomware que bloqueou o acesso a todos os processos dos pacientes, a equipa de Forensics é chamada para investigar. Em vez de ligarem os computadores infetados (o que poderia destruir provas), eles fazem cópias/imagens exatas dos discos rígidos(drives), depois analisam os logs dos servidores e o tráfego de rede para determinar a origem do incidente. Conseguem descobrir que o "paciente zero" foi um computador da receção que descarregou um anexo malicioso 48 horas antes, esta evidência pode depois ser usada em investigações legais.



External Threat Intelligence - uso de fontes externas (como a dark web, bases de dados de vulnerabilidades CVEs e dados de antivírus) para enriquecer a análise e prever incidentes antes de acontecerem. Ex: a empresa assina serviços que monitorizam a Dark Web e bases de dados globais de vírus, numa análise externa, descobrem que um grupo

de hackers está a partilhar e a vender informações sobre uma nova falha de segurança (vulnerabilidade) nos routers de uma marca específica que a empresa utiliza, graças a essa informação, a empresa consegue prever o incidente e atualizar o software dos seus routers antes que o ataque realmente aconteça.

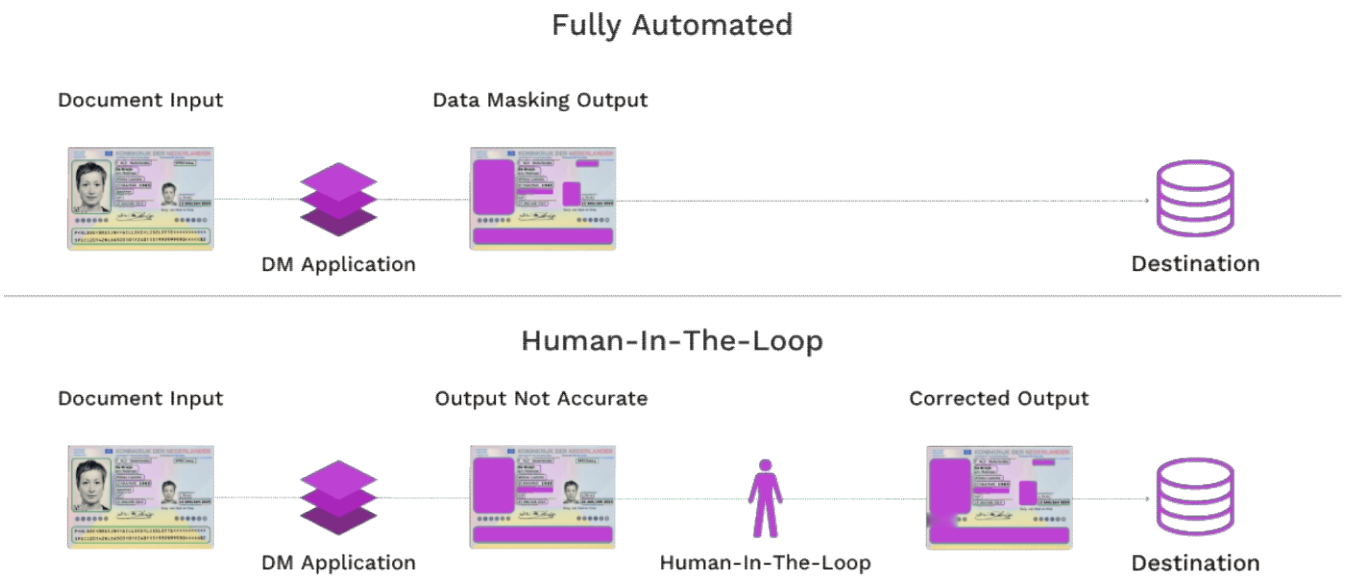


Segurança em Power BI

- **Row-Level Security (RLS - Segurança ao Nível da Linha)** - permite restringir o acesso aos dados com base no perfil do utilizador ex: um gerente da região Norte só consegue visualizar os dados de vendas da sua própria área.
    - **RLS Estático** - programador cria regras fixas.
    - **RLS Dinâmico** - fórmulas DAX (**USERPRINCIPALNAME()**) para filtrar automaticamente os dados com base no email de quem iniciou sessão.
- **Object-Level Security (OLS - Segurança ao Nível do Objeto)** - permite **ocultar tabelas ou colunas inteiras** de determinados utilizadores, **proteger campos sensíveis** como salários ou dados médicos.
- **Atribuição de Permissões (Power BI Service)** - regras e funções de segurança (RLS/OLS) são criadas no software Power BI Desktop, mas é apenas após a publicação no serviço online (Power BI Service) que o administrador associa os emails dos utilizadores às respetivas funções.

Implementação Prática de Segurança

Como proteger a informação na prática do dia a dia.

Data Masking e Anonimização - técnicas usadas para proteger dados reais (para cumprir o RGPD ou para criar ambientes de teste seguros).

- **Randomização** - trocar dados sensíveis por valores completamente aleatórios.
- **Substituição** - trocar os valores reais por dados fictícios, mas que parecem reais (ex: trocar um nome verdadeiro por outro nome inventado)
- **Criptografia** - proteger os dados através de algoritmos matemáticos
- **Shuffling** - baralhar a ordem dos dados originais ex: as idades reais são mantidas, mas a ordem é baralhada, atribuíndo as idades de uns clientes a outros